



IT Applications:

Electronic media in business and commerce

Security of banking transactions

Dariusz Caban
dariusz.caban@pwr.edu.pl



Electronic access to bank accounts



- Secure connection with the server using HTTPS
 - Server certificate should prevent spoofing
 - Certificate issued by a trusted CA (eg. VeriSign, Entrust)
 - Server should ensure secure level of encryption
- Access to the server should be authenticated
 - Simple passwords (can be hijacked by software installed on the client computer)
 - Single use passwords
 - Identification tokens and USB keys
- Some operations may require additional authorization
 - PIN sent via an independent channel of communication (SMS to the client mobile phone)
 - Phone authorization





Bank transfer

- Transfer funds from one account to another
 - Payer initiates transfer from his account, stating the account of the recipient (IBAN)
 - Payer bank sends a message to the recipient bank to remit funds to his account (using secure connection, e.g. SWIFT)
 - The message contains information required for interbank settlements
 - If no interbank settlements agreement, settlement via a correspondent bank
 - In Poland, ELIXIR run by Elektroniczna Izba Rozrachunkowa
- Transaction hazard
 - Relatively safe, authenticated payer and recipient
 - Danger related with anonymous recipient
 - Danger of fraud – transaction is irrevocable
- Smartphone payments





Payment cards

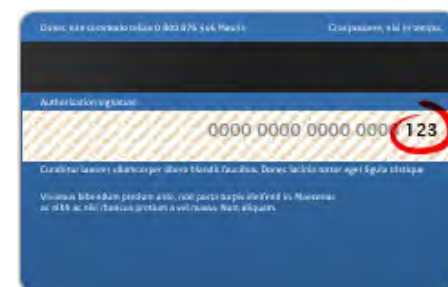
- Function
 - Credit cards
 - Charge cards (debit)
 - Pre-paid cards and electronic purse
- Classification
 - Cards with embossed print
 - Magnetic stripe cards
 - Smartcards
 - Contactless cards (RFID)
 - Virtual cards (ePayments)
 - Mobile
- Transactions
 - ATM (cash dispenser)
 - Point-of-sale
 - Remote payments (CNPT)





Card transactions

- Remote transactions (phone, web)
 - Card Not Present Transaction
 - Cardholder provides account name, card number, valid period (read from the card)
 - CVC2 / CVV2 / CID – 3-4 digit security code
 - A transaction may be revoked (chargeback)
 - High risk
 - Bank responsibility for fraudulent transactions
- Point of sale (POS)
 - Offline credit transactions (limited value)
 - Credit transactions with on-line validation of available credit
 - Charge card with on-line account charging
 - Transactions are often charged with a delay





Security of POS transactions

- Card authentication
 - Physical properties of the plastic, watermarks, etc.
 - CVV1 code recorded on the magnetic stripe
 - Encrypted communication between a POS terminal and a smartcard chip
- Transaction authorization
 - Based on data recorded on the card
 - Based on communication with the issuer bank
- Ensuring irrefutable transactions
 - Print out of the embossed text
 - Signature of the cardholder on the transaction
 - PIN entered by the cardholder and validated off-line or on-line
- Risk
 - For merchant: risk of fraud
 - For cardholder: risk of identity theft
 - Smartcards are safest (both for cardholder and merchant)
 - EMV (Europay, Mastercard, VISA) – common standard for communication between chip and POS terminal or ATM



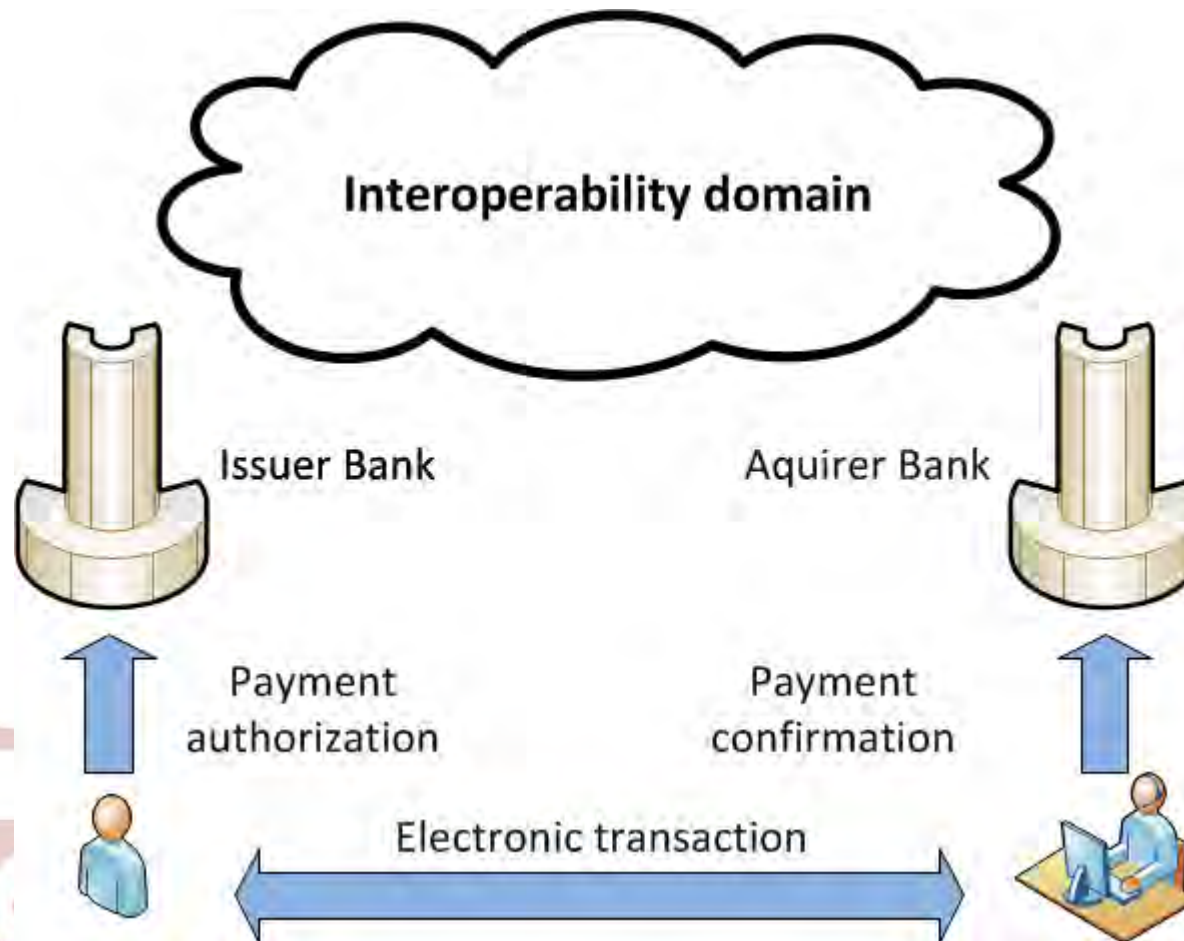
SET protocol



- Secure Electronic Transaction
 - Joint proposal by MasterCard and VISA
 - Protocol for secure Internet payments using a payment card
 - Ensures confidentiality
 - Ensures data integrity
 - Authenticates payer and merchant
- Specific problem – four organisations
 - Cardholder
 - Card issuer (bank or financial institution)
 - Merchant authorized to realize SET transaction
 - Acquirer bank



Electronic shopping experience



Electronic shopping experience



Client:

- Looks for goods and suppliers in the Internet (surfing)
- Selects goods to buy (shopping cart)
- Fills in the order (web form)
- Authorizes **electronic** payment with his bank (issuer bank)
- Sends the form with payment information to the merchant

Merchant:

- Requires confirmation of payment by his bank (acquirer)
- Acknowledges the transaction to the client
- Realizes the order
- Initiates money transfer from the issuer to the acquirer bank



Electronic shopping experience



- Merchant should not acquire information enabling access to the client bank account
 - To prevent fraud or stolen identity
- Banks should have only limited information about the transaction
 - No information about the goods being acquired



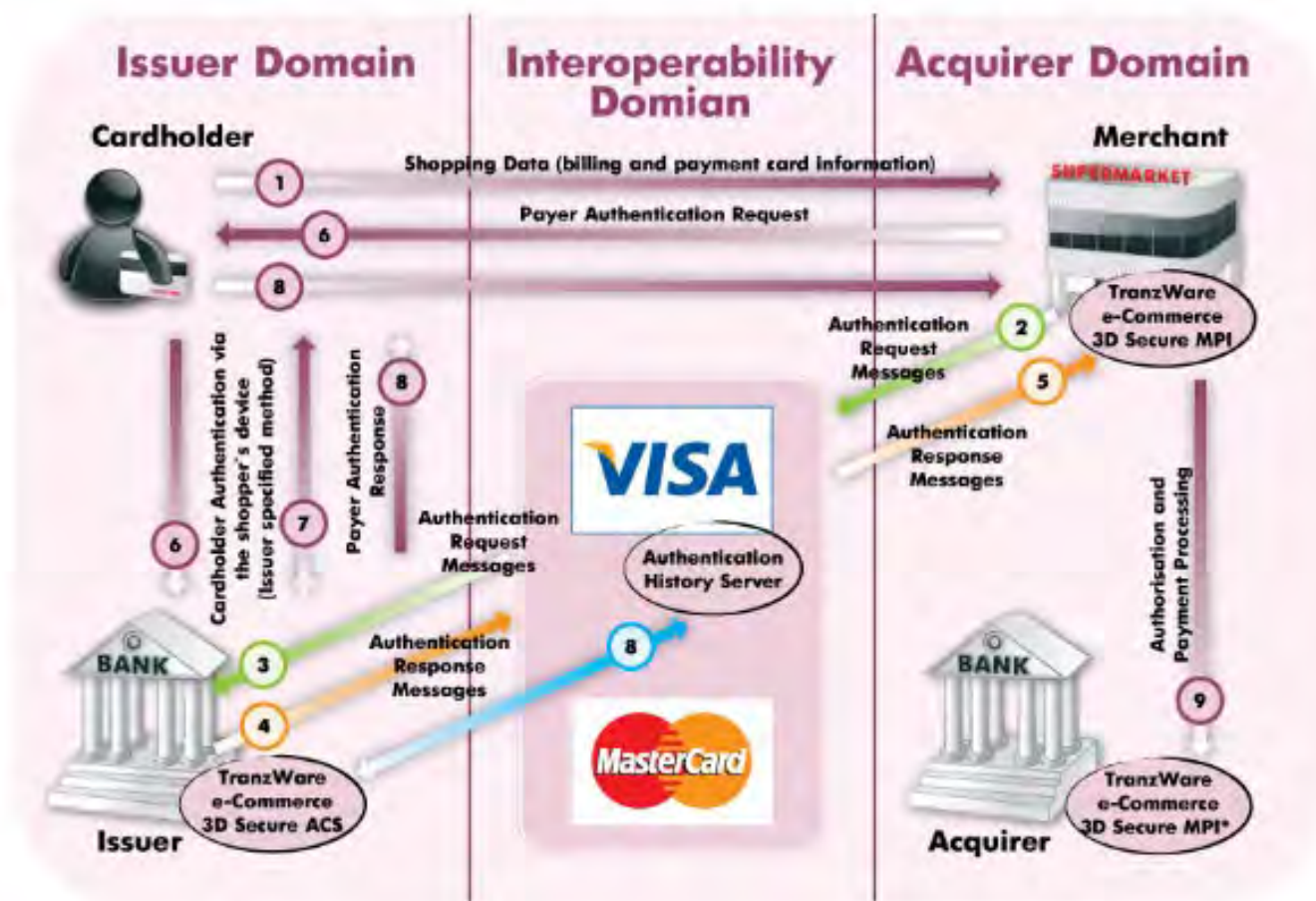
3D Secure



- It supersedes SET since 2005-2010
- Based on SSL and XML documents
- Products
 - VISA: Verified by VISA
 - MasterCard: Secure Payment Application (SPA)
- 3 Domains
 - Central systems of Visa / MasterCard (Interoperability Domain)
 - Payment gates (Acquirer Domain)
 - Banks – client accounts (Issuer Domain)



How does it work?



3D Secure cardholder experience



- Traditional access to cardholder account
- Payment gate opens a widget (dialog or iFrame) with direct access to the issuer bank
- Bank displays information that prevents spoofing (Personal Assurance Message)
- Cardholder must log into his account (usually using his password) to authorize the payment





Mobile phone card transactions

- Various payment schemes
 - Wallet (card data stored in an app)
 - One-time card (needs support from issuer bank)
 - Google Pay
- Google Pay
 - Application that supports card payments
 - Supports POS and CNPT transactions
 - Does not store card data in the phone
 - Improved security in case of phone theft



Google Pay – user experience



- User registers card in the application
 - Scans or inputs data read from the card
 - Application connects to the issuer bank and obtains a secure token (device specific card)
 - Data from the the card are not stored on the phone
 - Encrypted token is recorded
- Card payment
 - Token is decrypted using phone authentication (fingerprint scan)
 - Secure communication EMV is used to validate transaction
 - NFC is used to communicate with POS
 - SSL encryption is used to communicate with a shop supporting Google Pay

